



Introdução à segurança

© 2020, Amazon Web Services, Inc., ou suas afiliadas. Todos os direitos reservados.

Boas-vindas a Introdução à segurança.



O que você aprenderá

Principais pontos da lição

Você aprenderá a:

- Definir segurança em termos da tríade confidencialidade, integridade e disponibilidade (CIA)
- Identificar diferentes tipos de ameaças
- Identificar os componentes que compõem uma estratégia de segurança
- Explicar a diferença entre hacking, cracking e testes de penetração
- Citar os estágios do ciclo de vida da segurança
- Descrever como as leis e os regulamentos cibernéticos afetam a política de segurança organizacional



O que é segurança?

Discussão: Introdução à segurança



Qual seria o impacto na sua vida se a Internet ficasse inativa por alguns dias?

Qual seria o impacto se suas informações pessoais fossem roubadas?

Que tipos de controles você tem para evitar que isso aconteça?

Como computadores e tecnologia relacionada são integrados em nossos ambientes de trabalho e atividades pessoais, a segurança se tornou crucial para todos.

A segurança de TI ou segurança cibernética procura proteger computadores, redes, programas e dados contra acesso, alteração ou destruição não intencionais ou maliciosos. A segurança cibernética também visa a garantir que as funções comerciais e as tarefas pessoais ainda possam ser executadas com o mínimo de interferência e uma resposta ou taxa de produção razoável.

O que é segurança?



5

aws re/start

Esta é a tríade de confidencialidade, integridade e disponibilidade (CIA). Ao avaliar a segurança da informação, considere as três perspectivas importantes a seguir:

- **Confidencialidade** — Os dados privados estão protegidos para impedir o acesso não autorizado?
- **Integridade** — Existem medidas para garantir que os dados não tenham sido adulterados e sejam corretos e autênticos?

Esta é a tríade de confidencialidade, integridade e disponibilidade (CIA). Ao avaliar a segurança da informação, considere as três perspectivas importantes a seguir:

- **Confidencialidade** — Os dados privados estão protegidos para impedir o acesso não autorizado?
- **Integridade** — Existem medidas para garantir que os dados não tenham sido adulterados e sejam corretos e autênticos?
- **Disponibilidade** — Os usuários autorizados conseguem acessar os dados quando precisam deles?

Por que a segurança é importante?

A falta de segurança deixa a equipe e as organizações abertas para os seguintes riscos de segurança:



Roubo de identidade



Roubo de dados



Perda de serviços
e recursos de rede



Perda ou danos
à reputação comercial



Sabotagem ou
espionagem corporativa



6

- **Roubo de identidade** — Um evento tem como alvo informações de identificação pessoal (PII), como:
 - Nome
 - Data de nascimento
 - Senhas
 - Conta bancária
 - Números de cartão de crédito
- **Roubo de dados** — Um ladrão pode roubar dados confidenciais da empresa ou propriedade intelectual (IP). O ladrão pode tentar vender os dados ou

- **Roubo de identidade** — Um evento tem como alvo informações de identificação pessoal (PII), como:
 - Nome
 - Data de nascimento
 - Senhas
 - Conta bancária
 - Números de cartão de crédito
- **Roubo de dados** — Um ladrão pode roubar dados confidenciais da empresa ou propriedade intelectual (IP). O ladrão pode tentar vender os dados ou pedir um resgate para devolvê-los ao proprietário.
- **Perda de serviços ou recursos de rede** — Alguns eventos têm como alvo serviços de rede. Se esses serviços forem interrompidos, isso poderá afetar a capacidade de uma organização de conduzir negócios.
- **Sabotagem ou espionagem corporativa** — Uma empresa rival pode realizar espionagem para obter uma vantagem sobre a concorrência. Um funcionário insatisfeito pode lançar um evento de dentro da empresa para tentar sabotá-la.
- **Perda ou danos à reputação comercial** — Qualquer um desses eventos pode

levar a uma perda de reputação comercial. Se a capacidade da empresa de fornecer seus serviços for interrompida, os clientes poderão levar seus negócios para outro lugar. O roubo de propriedade intelectual pode prejudicar a capacidade da empresa de adquirir participação de mercado. Ou uma empresa pode perder dados de clientes, fazendo com que seus clientes fiquem sujeitos a roubo de identidade.

Tipos de ameaças

- A segurança apropriada ajuda a mitigar os seguintes tipos de ameaças:
 - Malware
 - Eventos de senha (dicionário, força bruta)
 - Negação de serviço distribuída (DDoS)
 - Man-in-the-middle (MitM)
 - Phishing
 - Engenharia social
 - Drive-by

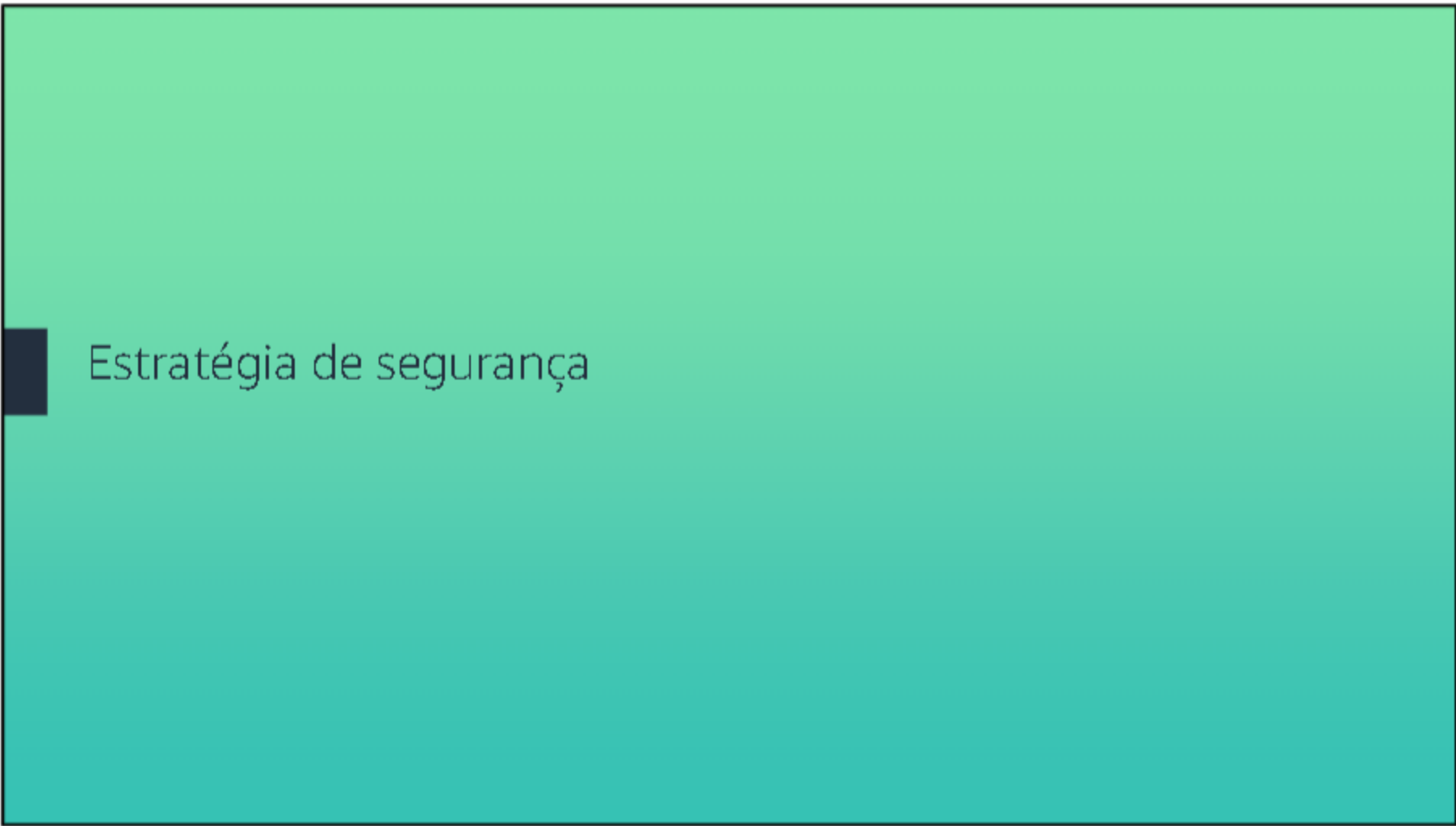
7



- **Malware:** software projetado para prejudicar, danificar ou obter acesso não autorizado a um sistema de computador. (Dicionário Oxford)
- **Eventos de senha:** um processo de recuperação de senhas de dados que foram armazenados ou transmitidos por um sistema de computador.
- **Negação de serviço distribuído (DDoS):** vários sistemas comprometidos são usados para comprometer um único sistema.
- **Man-in-the-middle:** uma parte externa transmite secretamente a comunicação entre duas partes, que acreditam que estão se comunicando



- **Malware:** software projetado para prejudicar, danificar ou obter acesso não autorizado a um sistema de computador. (Dicionário Oxford)
- **Eventos de senha:** um processo de recuperação de senhas de dados que foram armazenados ou transmitidos por um sistema de computador.
- **Negação de serviço distribuído (DDoS):** vários sistemas comprometidos são usados para comprometer um único sistema.
- **Man-in-the-middle:** uma parte externa transmite secretamente a comunicação entre duas partes, que acreditam que estão se comunicando diretamente entre si.
- **Phishing:** uma parte externa envia mensagens de e-mail que fingem ser uma empresa legítima para obter informações pessoais, como senhas ou números de cartão de crédito.
- **Engenharia social:** um evento que usa a interação humana para manipular uma pessoa a fim de violar procedimentos de segurança, obter acesso a detalhes de segurança e invadir sistemas.
- **Drive by:** os cibercriminosos usam sites não seguros para plantar códigos



Estratégia de segurança

Tipos de segurança

Segurança
do sistema

Segurança de
infraestrutura

Gerenciamento
de acesso

Gerenciamento
de identidades

Segurança
de dados

Segurança
de software

Segurança física

Estratégia



Segurança física



Gerenciamento
de acesso



Riscos de segurança
conhecidos e exploits
comuns



Políticas e
procedimentos

10

aws re/start

Com as devidas precauções, as chances de problemas de segurança são reduzidas e seu impacto quando um problema é descoberto pode ser reduzido. Entre as ferramentas disponíveis estão as seguintes:

- **Segurança física:** o acesso físico leva a um acesso mais amplo ou inadvertido. Comece controlando o acesso físico aos recursos (mas além do escopo deste curso).

Com as devidas precauções, as chances de problemas de segurança são reduzidas e seu impacto quando um problema é descoberto pode ser reduzido. Entre as ferramentas disponíveis estão as seguintes:

- **Segurança física:** o acesso físico leva a um acesso mais amplo ou inadvertido. Comece controlando o acesso físico aos recursos (mas além do escopo deste curso).
- **Gerenciamento de acesso:** controle o acesso aos recursos. Quanto mais o acesso for controlado, mais seguro será o ambiente. Considere os controles sobre quem tem acesso, identificando se alguém é quem diz ser e assim por diante.
- **Riscos de segurança conhecidos e exploits comuns:** reduza o escopo do impacto corrigindo vulnerabilidades assim que possível após o lançamento de um patch. Se a aplicação de patches não for possível, implemente outras proteções.
- **Políticas e procedimentos:** descreva como configurar e gerenciar todas as estratégias de segurança, como lidar com eventos de segurança quando eles ocorrem e assim por diante.

Discussão



As empresas podem implementar diferentes níveis e tipos de controles de segurança.

Quais são os impulsionadores para os controles de segurança implementados em redes e organizações modernas?

Controles de segurança



12

aws re/start

Os controles de segurança são definidos como três tipos: preventivo, detectivo e corretivo. Eles correspondem a três dos estágios do ciclo de vida da segurança. Para cada tipo de controle, medidas de segurança física, técnica e administrativa podem ser implementadas para garantir a confidencialidade, integridade e disponibilidade (CIA) das informações.

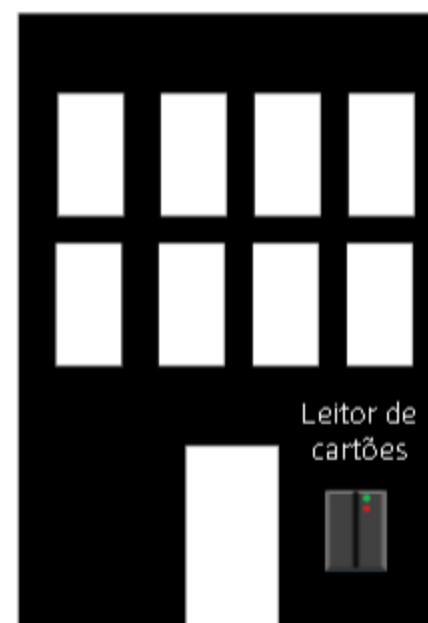
Nas lições subsequentes, você aprenderá sobre controles de segurança específicos que pode implementar em cada fase do ciclo de vida da segurança.

Compensação de controles de segurança

Seu data center principal tem um sistema de leitura de cartões. Quando você vai para um site alternativo, o data center não tem o mesmo sistema.

O que você faz para controlar quem pode entrar no data center alternativo?

Data center primário



Data center alternativo



aws re/start

Quando você precisa proteger várias propriedades, talvez não use os mesmos tipos de controles de segurança, mas ainda precisará atingir o mesmo nível de segurança.

O que é hacking?

Vetores de risco e alvos podem ser:

- Físicos
- Técnicos
- Sociais

Hacking e cracking



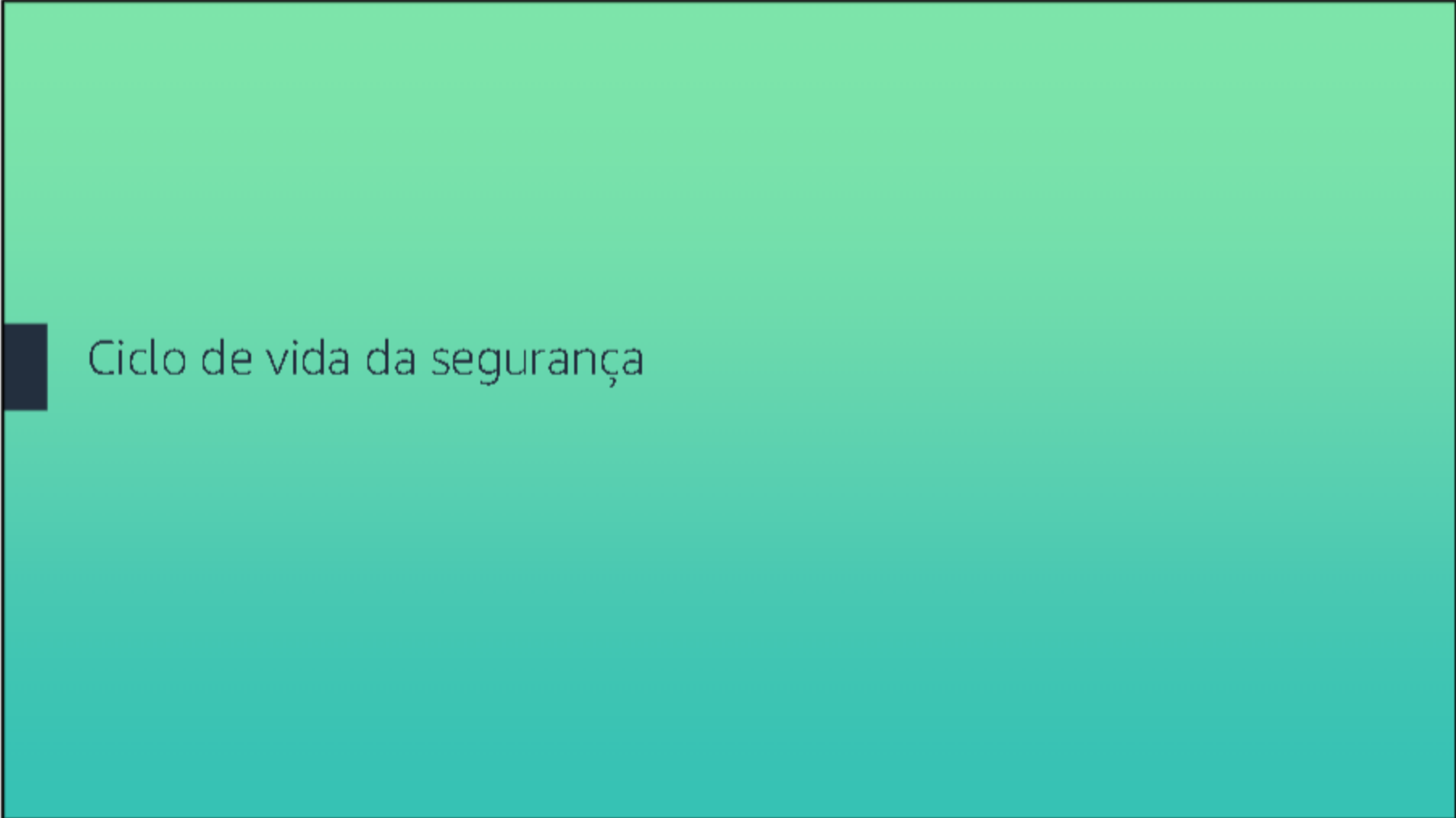
Acesso não autorizado

Teste de penetração



Testes para possíveis comprometimentos

aws re/start



Ciclo de vida da segurança

Ciclo de vida da segurança



Discussão



17

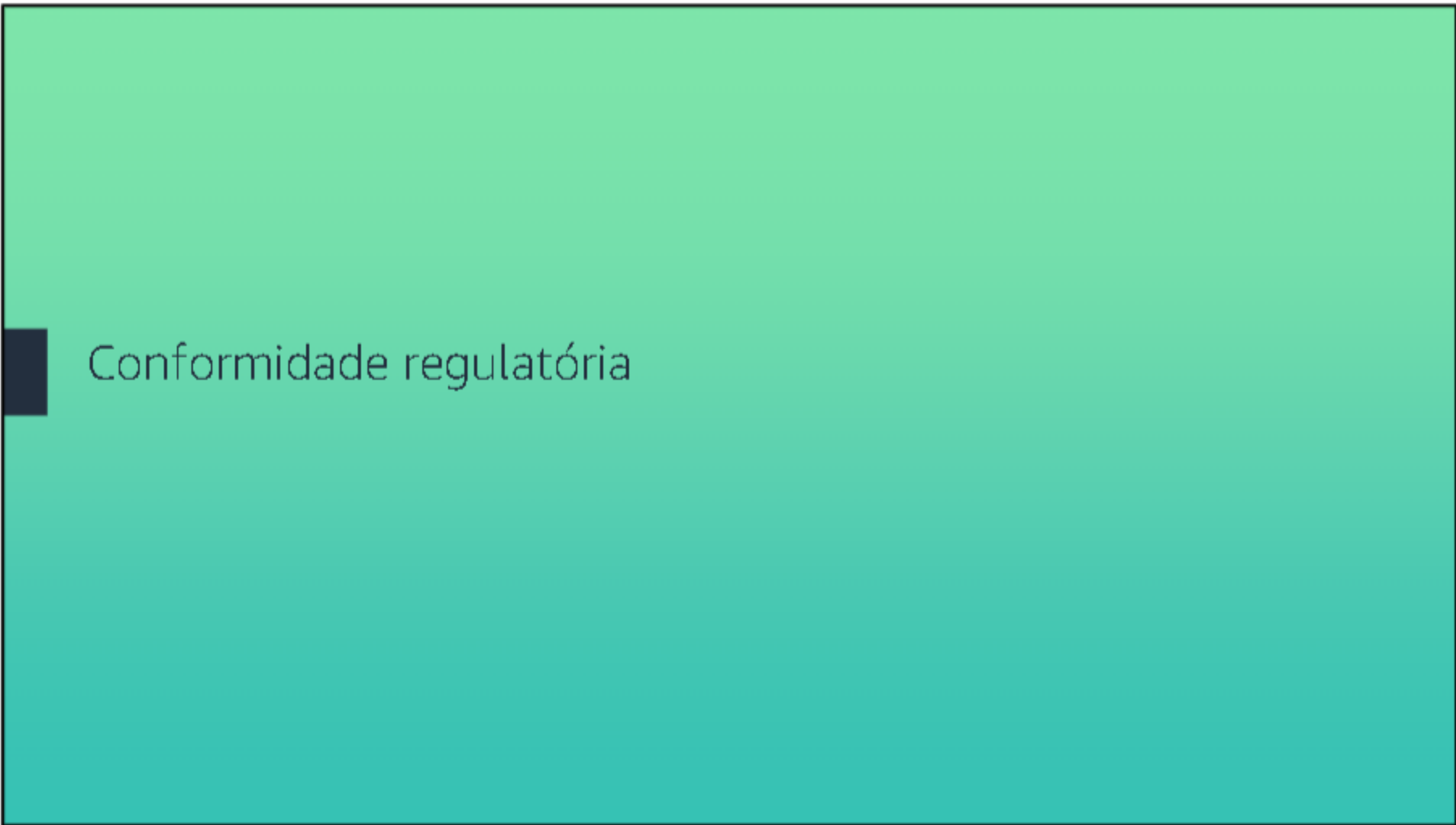
Como é o ciclo de vida da segurança em uma situação real?

Como o ciclo de vida da segurança difere entre os setores?

Quem define as regras para a necessidade de segurança individual?



Os frameworks de conformidade dão estrutura ao ciclo de vida associado às suas necessidades de segurança específicas. Os frameworks de conformidade são discutidos a seguir.



Conformidade regulatória

Conformidade regulatória

- Os controles de segurança geralmente são exigidos por regulamentos.

Normativo

- País
- Setor

Contratual

- SLA
- PLA

- Evite conflitos entre diferentes localidades, jurisdições ou culturas.

- Acordo de nível de serviço (SLA)
- Acordo de trabalho do projeto (PLA)

Padrões de segurança cibernética

- Os padrões de TI continuam evoluindo. Nenhum padrão único é infalível ou à prova de futuro para o seu ambiente.
- Organizações focadas no desenvolvimento de padrões:



- National Institute of Standards and Technology (NIST)
- Agência da União Europeia para a Segurança Cibernética (ENISA)
- European Telecommunications Standards Institute (ETSI)
- International Organization for Standardization (ISO)
- Internet Engineering Task Force (IETF)
- Institute of Electrical and Electronics Engineers (IEEE)
- Committee of Sponsoring Organizations (COSO)

Conformidade

- Autoridade externa:
 - *Governo ou leis*. Conformidade obrigatória
 - *Padrões abertos*. Conformidade obrigatória para participar
 - *Práticas recomendadas*. Conformidade opcional
- O não cumprimento tem consequências:
 - *Governo ou leis*. Punições civis, criminais ou financeiras
 - *Padrões abertos*. Punições financeiras ou participação negada
 - *Práticas recomendadas*. Perda de clientes, parceiros ou receita
- Relatórios adequados são necessários para comprovar a conformidade.

Padrão de segurança do setor de cartões de pagamento (PCI)

- O PCI é um conjunto regulamentado de requisitos destinados a manter um ambiente seguro.
 - Os requisitos se concentram em vários aspectos da segurança de dados.
- Todas as entidades envolvidas no processamento de dados de cartões de pagamento devem cumprir os padrões de segurança do PCI.
- O PCI Security Standards Council também fornece procedimentos de avaliação de segurança.

Para obter mais informações sobre o PCI:
<https://www.pcisecuritystandards.org/>

Padrões de conformidade: União Europeia

Basicamente, o **Regulamento Geral de Proteção de Dados (RGPD)** é um conjunto de regulamentos criados para fornecer aos **cidadãos** da **União Europeia (UE)** um controle mais aprimorado sobre seus dados.



23

aws re/start

O Regulamento Geral de Proteção de Dados (RGPD) é um conjunto de regulamentos criados para fornecer aos cidadãos da *União Europeia (UE)* um controle mais aprimorado sobre sua privacidade e segurança de dados. O RGPD fornece uma abordagem abrangente de proteção para cidadãos da UE e princípios de responsabilidade para conformidade.

O RGPD aplicará punições severas àqueles que violarem os padrões de privacidade e segurança. Algumas punições podem chegar a dezenas de milhões de euros.

O Regulamento Geral de Proteção de Dados (RGPD) é um conjunto de regulamentos criados para fornecer aos cidadãos da *União Europeia (UE)* um controle mais aprimorado sobre sua privacidade e segurança de dados. O RGPD fornece uma abordagem abrangente de proteção para cidadãos da UE e princípios de responsabilidade para conformidade.

O RGPD aplicará punições severas àqueles que violarem os padrões de privacidade e segurança. Algumas punições podem chegar a dezenas de milhões de euros.

Para entender melhor a conformidade com o RGPD, analise a seguinte lista de leis para o processamento de dados de cidadãos da UE:

- (a) Se o titular dos dados tiver dado consentimento para o processamento de seus dados pessoais
- (b) Cumprir obrigações contratuais com um titular de dados, ou para tarefas a pedido de um titular de dados que esteja em processo de celebração de um contrato
- (c) Cumprir as obrigações legais de um controlador de dados
- (d) Proteger os interesses vitais de um titular de dados ou outro indivíduo
- (e) Executar uma tarefa no interesse público ou na autoridade oficial
- (f) Para os interesses legítimos de um controlador de dados ou de um

Estados Unidos: HIPAA

- Lei de portabilidade e responsabilidade do seguro de saúde nos EUA de 1996
 - Modernizou o manuseio de informações de saúde.
 - Estipula como as informações de identificação pessoal devem ser protegidas.
 - Aborda as limitações na cobertura de seguro de saúde.
 - Consiste em cinco títulos que especificam as leis.
- Exemplo: os profissionais de saúde não divulgam identidades dos pacientes por telefone aos membros da família.

Portabilidade e Responsabilidade do Seguro de Saúde (HIPAA) é uma lei federal dos EUA que protege as informações de saúde dos pacientes de serem divulgadas sem a permissão do paciente.

Padrões de conformidade: União Europeia

Basicamente, o **Regulamento Geral de Proteção de Dados (RGPD)** é um conjunto de regulamentos criados para fornecer aos **cidadãos** da **União Europeia (UE)** um controle mais aprimorado sobre seus dados.



O Regulamento Geral de Proteção de Dados (RGPD) é um conjunto de regulamentos criados para fornecer aos cidadãos da *União Europeia (UE)* um controle mais aprimorado sobre sua privacidade e segurança de dados. O RGPD fornece uma abordagem abrangente de proteção para cidadãos da UE e princípios de responsabilidade para conformidade.

O RGPD aplicará punições severas àqueles que violarem os padrões de

O Regulamento Geral de Proteção de Dados (RGPD) é um conjunto de regulamentos criados para fornecer aos cidadãos da *União Europeia (UE)* um controle mais aprimorado sobre sua privacidade e segurança de dados. O RGPD fornece uma abordagem abrangente de proteção para cidadãos da UE e princípios de responsabilidade para conformidade.

O RGPD aplicará punições severas àqueles que violarem os padrões de privacidade e segurança. Algumas punições podem chegar a dezenas de milhões de euros.

Para entender melhor a conformidade com o RGPD, analise a seguinte lista de leis para o processamento de dados de cidadãos da UE:

- (a) Se o titular dos dados tiver dado consentimento para o processamento de seus dados pessoais
- (b) Para cumprir obrigações contratuais com um titular de dados, ou para tarefas a pedido de um titular de dados que esteja em processo de celebração de um contrato
- (c) Para cumprir as obrigações legais de um controlador de dados
- (d) Para proteger os interesses vitais de um titular de dados ou outro indivíduo
- (e) Executar uma tarefa no interesse público ou na autoridade oficial
- (f) Para os interesses legítimos de um controlador de dados ou de um

Padrões de conformidade: Rússia

Lei federal **russe** sobre dados pessoais:

- O consentimento do indivíduo é necessário.
- Um titular de dados pessoais pode revogar o consentimento concedido anteriormente.
- A transferência de dados pessoais para fora da federação russa requer proteção adequada no país de destino.

- Implementado em 27 de julho de 2006
- O consentimento do indivíduo é necessário para processar dados pessoais.
- Um titular de dados pessoais tem o direito, a qualquer momento, de revogar

- Implementado em 27 de julho de 2006
- O consentimento do indivíduo é necessário para processar dados pessoais.
- Um titular de dados pessoais tem o direito, a qualquer momento, de revogar seu consentimento previamente concedido.

Geralmente, para transferir dados pessoais para fora da Federação Russa, o operador deve garantir que os direitos dos titulares de dados pessoais tenham proteção adequada no país de destino.

Padrões de conformidade: China

Lei de segurança cibernética da [República Popular da China](#):

- Requer que dados selecionados sejam armazenados na China.
- Permite que as autoridades chinesas realizem verificações pontuais nas operações de rede de uma empresa.

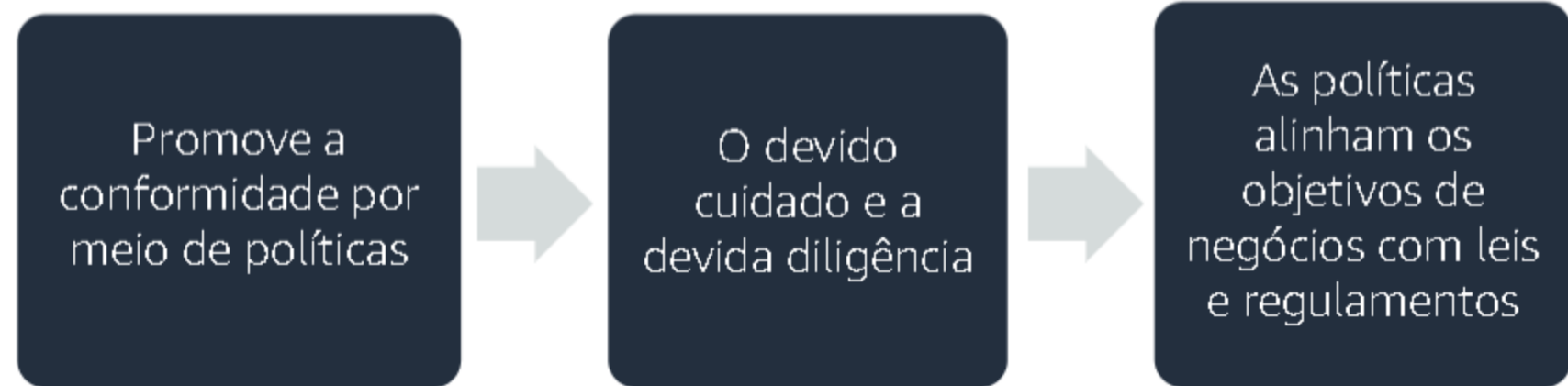
- Implementado em 1º de junho de 2017.
- Exige que as operadoras de rede armazenem dados selecionados na China e permite que as autoridades chinesas realizem verificações pontuais nas operações de rede de uma empresa.

- Implementado em 1º de junho de 2017.
- Exige que as operadoras de rede armazenem dados selecionados na China e permite que as autoridades chinesas realizem verificações pontuais nas operações de rede de uma empresa.
- A lei criou:
 - O princípio da soberania do ciberespaço
 - Definiu as obrigações de segurança dos provedores de produtos e serviços de Internet
 - Aperfeiçoou ainda mais as regras de proteção de informações pessoais
 - Estabeleceu um sistema de segurança para infraestrutura de informações importantes
 - Instituiu regras para a transmissão transnacional de dados em infraestrutura de informações críticas

Outros padrões

Leis e regulamentos	EUA	Canadá	UE
Sarbanes-Oxley Act (SOX – Lei Sarbanes-Oxley)	X		
Gramm-Leach-Bliley Act (GLBA – Lei Gramm-Leach-Bliley)	X		
Federal Information Security Management Act (FISMA – Lei Federal de Gerenciamento de Segurança da Informação)	X		
Regulamento Geral de Proteção de Dados (RGPD)			X
Personal Information Protection and Electronic Documents Act (PIPEDA – Lei de Proteção de Informações Pessoais e Documentos Eletrônicos)		X	
Financial Industry Regulatory Authority (FINRA – Autoridade reguladora do setor financeiro)	X		
Family Educational Rights and Privacy Act (FERPA – Lei de Direitos Educacionais e Privacidade da Família)	X		
Dodd-Frank Wall Street Reform and Consumer Protection Act (Lei de Reforma e Proteção ao Consumidor de Dodd-Frank Wall Street) – EUA	X		

Política de conformidade e da empresa



Principais conclusões



© 2020, Amazon Web Services, Inc., ou suas afiliadas. Todos os direitos reservados.

30

- Considere essas perspectivas ao abordar a segurança da informação: **confidencialidade, integridade e disponibilidade**.
- Os tipos comuns de problemas de segurança incluem **malware, phishing e engenharia social**.
- Uma boa estratégia de segurança que implementa as fases do ciclo de vida da segurança: **prevenção, detecção, resposta e análise**.
- Existem vários **padrões de conformidade de segurança do setor** para fornecer um framework para impor boas práticas de segurança.

aws re/start

As principais conclusões desta lição:

- Três perspectivas ao abordar a segurança da informação: confidencialidade, integridade e disponibilidade.

